

Министерство образования Республики Беларусь

Учреждение образования
«БЕЛОРУССКИЙ ГОСУДАРСТВЕННЫЙ УНИВЕРСИТЕТ
ИНФОРМАТИКИ И РАДИОЭЛЕКТРОНИКИ»

Факультет информационных технологий и управления
Кафедра интеллектуальных информационных технологий

Лабораторная работа №4

по дисциплине «Проектирование защищенных интеллектуальных
информационных систем»

на тему «Безопасность работы серверов в сети Internet.

Часть 2. Усовершенствование системы безопасности удалённых серверов»

Выполнил студент гр. 321701

Ковальчук В. Н.
Самович В. М.

Проверил

Сальников Д. А.

Минск 2026

Цель: установить на удалённый сервер систему обнаружения и предотвращения вторжений и оценить, как она изменила попытки атак на сервер.

Задание:

а) Установить и настроить программное обеспечение, позволяющее усовершенствовать защиту сервера, согласно варианту.

б) Выполнить анализ данных логов различных подсистем, в том числе SSH и веб-сервера удалённого сервера, за несколько дней.

в) Оформить отчёт о проделанной работе.

Постановка задачи. Вариант – OSSEC. Он установлен на тот же сервер (212.192.9.89, test-lab4.work.gd), что и в лабораторной работе №4.1, и работает с 5 сентября 19:16 UTC. Данные «до» взяты из отчёта №4.1, данные «после» – за 33 суток работы системы (по 8 октября).

Описание установленного программного обеспечения

OSSEC – система обнаружения вторжений уровня хоста (HIDS): она работает на самом защищаемом сервере и читает его журналы, а не сетевой трафик. Она решает четыре задачи:

- **Анализ журналов.** Читает указанные файлы, разбирает строки декодерами и сверяет с правилами; при совпадении создаёт тревогу с уровнем важности от 0 до 15.

- **Контроль целостности файлов (syscheck)** – периодически сверяет контрольные суммы системных файлов.

- **Поиск руткитов (rootcheck).**

- **Активный ответ.** При тревоге уровня 6 и выше запускает скрипты: `firewall-drop` добавляет правило `iptables DROP` для IP-источника, `host-deny` вносит его в `/etc/hosts.deny`. Блокировка снимается через 600 секунд. Именно активный ответ делает систему не только IDS, но и IPS.

Принцип работы. OSSEC собран из исходного кода (пакета для Ubuntu 24.04 нет) и установлен в режиме `local`: сервер и агент на одной машине. `ossec-logcollector` читает файлы и передаёт строки `ossec-analysisd`, тот применяет декодеры и правила, а при срабатывании правила уровня 6 и выше `ossec-execd` запускает скрипт блокировки. В `allow_list` внесены адрес сервера и подсеть VPN, чтобы система не заблокировала администратора (листинг 1).

```

1 <global>
2   <allow_list>127.0.0.1</allow_list>
3   <allow_list>::1</allow_list>
4   <allow_list>212.192.9.89</allow_list>
5   <allow_list>10.0.0.0/24</allow_list>
6 </global>
7
8 <active-response>
9   <command>host-deny</command>
10  <location>local</location>
11  <level>6</level>
12  <timeout>600</timeout>
13 </active-response>
14 <active-response>
15   <command>firewall-drop</command>
16   <location>local</location>
17   <level>6</level>
18   <timeout>600</timeout>
19 </active-response>
20
21 <localfile><log_format>syslog</log_format><location>/var/log/auth.log</location></localfile>
22 <localfile><log_format>syslog</log_format><location>/var/log/syslog</location></localfile>
23 <localfile><log_format>syslog</log_format><location>/var/log/dpkg.log</location></localfile>
24 <localfile><log_format>syslog</log_format><location>/var/log/caddy/access.log</location></localfile>

```

Листинг 1 – Фрагмент конфигурации OSSEC

Анализируемые подсистемы и файлы

Анализируются те же подсистемы, что в №4.1: SSH (/var/log/auth.log) и веб-сервер Caddy (/var/log/caddy/access.log), а также сам OSSEC:

- /var/ossec/logs/alerts/alerts.log – все тревоги: правило, уровень, IP-источник и исходная строка журнала;
- /var/ossec/logs/active-responses.log – выполненные блокировки и снятия блокировок.

Примеры записей – в листинг 2.

```

1 == alerts.log: brute-force alert (rule 5712, level 10) ==
2 ** Alert 1789862739.45135: mail - syslog,sshd,authentication_failures,
3 2026 Sep 20 00:05:39 weaselcloud-3522->/var/log/auth.log
4 Rule: 5712 (level 10) -> 'SSHD brute force trying to get access to the system.'
5 Src IP: 109.160.32.83
6
7 == active-responses.log: first ban and its removal ==
8 Sat Sep 5 19:44:34 UTC 2026 /var/ossec/active-response/bin/firewall-drop.sh add - 193.46.255.86 1788637474.69
9 ↪ 2502
10
11 Sat Sep 5 19:55:05 UTC 2026 /var/ossec/active-response/bin/firewall-drop.sh delete - 193.46.255.86
12 ↪ 1788637474.69 2502
13
14
15 == iptables -S OSSEC / tail /etc/hosts.deny (8 Oct) ==
16 -A OSSEC -s 45.148.10.157/32 -j DROP
17 ALL:45.148.10.157
18
19
20 == alerts.log: false alarm on a Caddy JSON line (rule 1003, level 13) ==
21 Rule: 1003 (level 13) -> 'Non standard syslog message (size too large).'
```

Листинг 2 – Примеры записей OSSEC: тревога, блокировка, снятие блокировки

Анализ запросов из сети Internet до и после настройки

Период «до» – 3–5 сентября (47,6 часа, отчёт №4.1). Период «после» – 6 сентября – 8 октября (790 часов); первые пять часов работы OSSEC (5 сентября) уже удалены ротацией журнала SSH. Периоды разной длины, поэтому сравниваются показатели в час и на один адрес. Данные получены скриптом `analyze.sh` (листинг 3, листинг 4). Строки вида «message repeated N times» скрипт считает за одну, поэтому реальное число попыток немного больше.

Показатель (SSH)	До OSSEC	После OSSEC
Неудачных попыток входа	13 458	57 663
Попыток в час	283	73
Уникальных IP-адресов	64	1 298
Попыток на один IP в среднем	210	44
Доля самого активного IP	52 %	5 %
Доля попыток под root	71,7 %	46,1 %
Успешных входов с адресов из перебора	0	0

Таблица 1 – Попытки входа по SSH до и после запуска OSSEC

Результат. Интенсивность перебора снизилась с 283 до 73 попыток в час (в 3,9 раза), среднее число попыток на один адрес – с 210 до 44, а доля самого активного адреса – с 52 % до 5 %: теперь ни один источник не может долго и безнаказанно перебирать пароли. Доступа не получил ни один адрес из перебора: все успешные входы (26) – с адреса VPN администратора 10.0.0.4.

Но сравнивать нужно осторожно. База «до» – всего двое суток, и 52 % попыток дал один адрес; без него интенсивность была 136 в час, то есть снижение примерно вдвое. Кроме того, перебор со временем растёт: около 1 350 попыток в сутки в первые две недели и около 2 000 в последние. Число уникальных адресов выросло до 1 298: OSSEC ограничивает то, сколько может сделать один адрес, но не то, сколько адресов приходит.

Работа активного ответа. OSSEC создал 150 078 тревог, из них 92 % – уровня 5 (одиночные неудачные входы, ниже порога блокировки), 6 665 – уровня 10 (перебор), 485 – уровня 13 (ложные, см. ниже). Выполнено 4 745 блокировок 290 адресов (≈ 144 в сутки). Первая блокировка произошла через 28 минут после запуска, её вызвало правило 2502 («пользователь несколько раз ошибся в пароле»). Адреса сервера и VPN в журнале блокировок ни разу не появились – белый список работает.

```

1  Period: 2026-09-06 2026-10-08
2  Failed password attempts: 57663
3  Unique source IPs: 1298
4  Attempts for root: 26568
5
6  Top 10 source IPs:
7      2949 2.57.121.112
8      1884 2.57.121.25
9      1867 103.97.215.11
10     1701 193.46.255.86
11     1038 45.148.10.152
12     986 45.148.10.157
13     964 45.148.10.141
14     961 45.148.10.151
15     953 193.47.62.69
16     899 62.60.130.242
17
18  Top 10 user names:
19     26568 root
20     5475 admin
21     833 user
22     830 ubuntu
23     510 test
24     448 administrator
25     430 debian
26     300 deploy
27     276 ftpuser
28     261 developer
29
30  Failed attempts per day:
31     1295 2026-09-06
32     1610 2026-09-07
33     1297 2026-09-08
34     1170 2026-09-09
35     1735 2026-09-10
36     1661 2026-09-11
37     1163 2026-09-12
38     1539 2026-09-13
39     1453 2026-09-14
40     1309 2026-09-15
41     1377 2026-09-16
42     1114 2026-09-17
43     1056 2026-09-18
44     1156 2026-09-19
45     2081 2026-09-20
46     1685 2026-09-21
47     2357 2026-09-22
48     1880 2026-09-23
49     2090 2026-09-24
50     2293 2026-09-25
51     2495 2026-09-26
52     1899 2026-09-27
53     2013 2026-09-28
54     1295 2026-09-29
55     1489 2026-09-30
56     1677 2026-10-01
57     2161 2026-10-02
58     2319 2026-10-03
59     2783 2026-10-04
60     1867 2026-10-05
61     2072 2026-10-06
62     2143 2026-10-07
63     2129 2026-10-08
64
65  Successful logins (method user ip):
66     24 publickey for root from 10.0.0.4
67     2 password for devv from 10.0.0.4

```

Листинг 3 – Сводка по SSH, 6 сентября – 8 октября

```

1 Alerts: 150078
2
3 Alerts by level:
4   3197 2
5   139 3
6   348 4
7 138791 5
8   399 7
9   54 8
10  6665 10
11   485 13
12
13 Top 8 rules:
14 65364 5710 (level 5) -> 'Attempt to login using a non-existent user'
15 48443 5503 (level 5) -> 'User login failed.'
16 24879 5716 (level 5) -> 'SSHD authentication failed.'
17 4743 2502 (level 10) -> 'User missed the password more than one time'
18 3177 1002 (level 2) -> 'Unknown problem somewhere in the system.'
19 1331 5712 (level 10) -> 'SSHD brute force trying to get access to the system.'
20 485 1003 (level 13) -> 'Non standard syslog message (size too large).'
21 457 5551 (level 10) -> 'Multiple failed logins in a small period of time.'
22
23 Bans (firewall-drop add): 4745, unique IPs: 290
24
25 Most banned IPs:
26 404 45.148.10.152
27 382 45.148.10.157
28 379 45.148.10.151
29 375 193.47.62.69
30 372 45.148.10.141
31 351 62.60.130.242
32 338 62.60.130.253
33 251 62.60.130.201
34 125 193.46.255.86
35 41 109.160.32.40

```

Листинг 4 – Сводка по OSSEC, 5 сентября – 8 октября

Ограничения. Анализ показал три слабых места настройки.

а) **Нападающие возвращаются.** Блокировка длится 600 секунд, и настойчивые источники продолжают после неё: восемь самых частых адресов дали 2852 блокировки (60%), а три подсети (45.148.10.0/24, 109.160.32.0/24, 62.60.130.0/24) – 75%. Рекордсмен 45.148.10.152 заблокирован 404 раза.

б) **«Медленный» перебор не виден.** Три самых активных источника (2.57.121.112, 2.57.121.25, 103.97.215.11, всего 6700 попыток) ни разу не были заблокированы: перебор идёт редко, и порог правила 5712 (6 событий за 120 с) не достигается.

в) **Веб-сервер OSSEC не защищает.** Журнал Caddy ведётся в JSON, а OSSEC читает его как syslog и не разбирает: ни одного веб-правила не сработало, хотя в журнале 2930 ответов 404. Зато длинные JSON-строки вызвали 485 ложных тревог уровня 13 («size too large») – самых «серьёзных» в журнале.

Дополнительно сработал контроль целостности: 253 тревоги, в основном после обновления системных программ (apt).

Сравнение с аналогами

Система	Тип	Источник данных	Особенность
OSSEC	HIDS + активный ответ	Журналы на хосте	Проста в установке на один сервер, блокировка через скрипты
Snort	NIDS/NIPS	Сетевые пакеты	Сигнатурный анализ трафика, нужны правила под протокол
Suricata	NIDS/NIPS	Сетевые пакеты	Совместима с правилами Snort, многопоточная, разбирает HTTP и TLS
Tripwire	HIDS (FIM)	Контрольные суммы файлов	Только контроль целостности, без анализа журналов и сети
Zeek (Bro)	NIDS	Сетевые пакеты	Подробное протоколирование и анализ, без блокировки

Таблица 2 – OSSEC и альтернативы из задания

Для одного сервера с двумя службами HIDS удобнее: он использует уже существующие журналы, не требует отдельного сенсора и не нагружает единственный процессор разбором всего трафика.

Демонстрация работы установленного программного обеспечения

Работа OSSEC показана записями журналов: тревога, блокировка и её снятие (листинг 2), а также итоговой сводкой (листинг 4). На сервере активны процессы `ossec-analysisd`, `ossec-logcollector`, `ossec-syscheckd`, `ossec-execd`, а текущие блокировки видны в цепочке `iptables -S OSSEC`.

Выводы

Семантически работа показала разницу между обнаружением и предотвращением. Журналы из №4.1 только фиксировали перебор (283 попытки в час, один адрес – 52 %). После запуска OSSEC с активным ответом за 33 суток выполнено 4 745 автоматических блокировок 290 адресов, интенсивность перебора снизилась до 73 попыток в час, а доля самого активного адреса – до 5 %. Но система ограничивает возможности каждого источника, а не число источников: уникальных адресов стало 1 298, а

перебор в последние недели вырос. Выявлены и слабые места: фиксированная блокировка на 600 секунд не останавливает настойчивые подсети, медленный перебор порог не достигает, а JSON-журнал веб-сервера OSSEC не разбирает.

С прагматической точки зрения HIDS оправдал себя: установка на один сервер, чтение готовых журналов, блокировка через `iptables`. Полезные доработки: увеличивать срок блокировки для повторяющихся адресов, добавить правило на медленный перебор, подключить декодер для JSON-журнала Caddy и, главное, отключить вход `root` и вход по паролю, после чего подбор пароля теряет смысл.